



Dompé

DOCUMENTAZIONE TECNICA

Sicurezza e conformità

Modello di sicurezza, controlli implementati, deviazioni consapevoli e stato di conformità



Campo	Valore
Applicativo	Guest Portal — Cisco Catalyst 9800 Guest Management Desk
Indirizzo (produzione)	https://guestportal.dompe.com
Documento	SEC — Sicurezza e conformità
Versione	1.2
Data di emissione	25 settembre 2026
Stato	Emesso
Destinatari	Security, Compliance, IT Infrastructure, Sviluppo
Classificazione	Uso interno
Repository di riferimento	github.com/ACF-Dompe/Centralino
Revisione del codice	main · 3338398 (+ modifiche non ancora committate)

Indice

1	Scopo e riferimenti	3
2	Perimetro e superficie	4
2.1	Esposizione	4
2.2	Superficie applicativa.....	4
3	Autenticazione	5
3.1	SSO SAML 2.0	5
3.2	Cache anti-replay persistita	6
3.3	L'applicazione non impone il metodo di autenticazione	6
3.4	Sessione	6
4	Autorizzazione	8
4.1	Il principio.....	8
4.2	Ruoli e ambito.....	8
4.3	Fail closed.....	9
4.4	Amministratori per convenzione	9
4.5	Isolamento fra sedi	9
5	Gestione dei segreti	10
6	Protezione dei dati.....	11
7	Sicurezza verso i controller	12
8	Supply chain e immagini	13
9	Registrazione e audit.....	14
10	Deviazioni consapevoli.....	15
10.1	D1 — Accesso di emergenza senza secondo fattore	15
10.2	D2 — Verifica della chiave host SSH disattivata	16
10.3	D3 — Verifica del certificato TLS dei controller disattivata	17
10.4	D4 — Password dei controller leggibile e modificabile via HTTP	17
11	Stato di conformità	19
12	Backlog di remediation	20

1 Scopo e riferimenti

Questo documento descrive il modello di sicurezza del Guest Portal, i controlli effettivamente implementati nel codice, le deviazioni assunte consapevolmente con i relativi controlli compensativi, e lo stato di conformità rispetto alla baseline di piattaforma.

Riferimento	Valore
Baseline	Azure Container Platform — AI Development Guidelines, Standard Architecture Definition v1.5 (2026-06-15)
Ambito	Non-GxP
Fonte primaria	COMPLIANCE.md nel repository, mantenuto insieme al codice
Classificazione dei dati	Dati personali comuni (identificativi e contatti di visitatori e operatori). Nessun dato particolare.

Tabella 1 — *Riferimenti normativi e di ambito.*

2 Perimetro e superficie

2.1 Esposizione

- L'ambiente Container Apps è **internal**: non possiede alcun indirizzo pubblico.
- L'unico punto di ingresso è l'**Application Gateway con WAF v2**, in modalità **Prevention**, su listener HTTPS.
- Le due applicazioni sono create con ingress **external**, che in Container Apps significa «raggiungibile dalla rete virtuale», non «esposto su Internet». La conformità «nessun ingress pubblico» è garantita dall'ambiente.
- **CORS è assente per scelta**: frontend e backend condividono l'origine e il browser non effettua mai una richiesta cross-origin. Abilitarlo ampliherebbe la superficie senza alcun beneficio.
- L'unico traffico in uscita verso la rete aziendale è quello diretto ai controller: HTTPS 443 e SSH 22, con egress ristretto alla rete di gestione.

2.2 Superficie applicativa

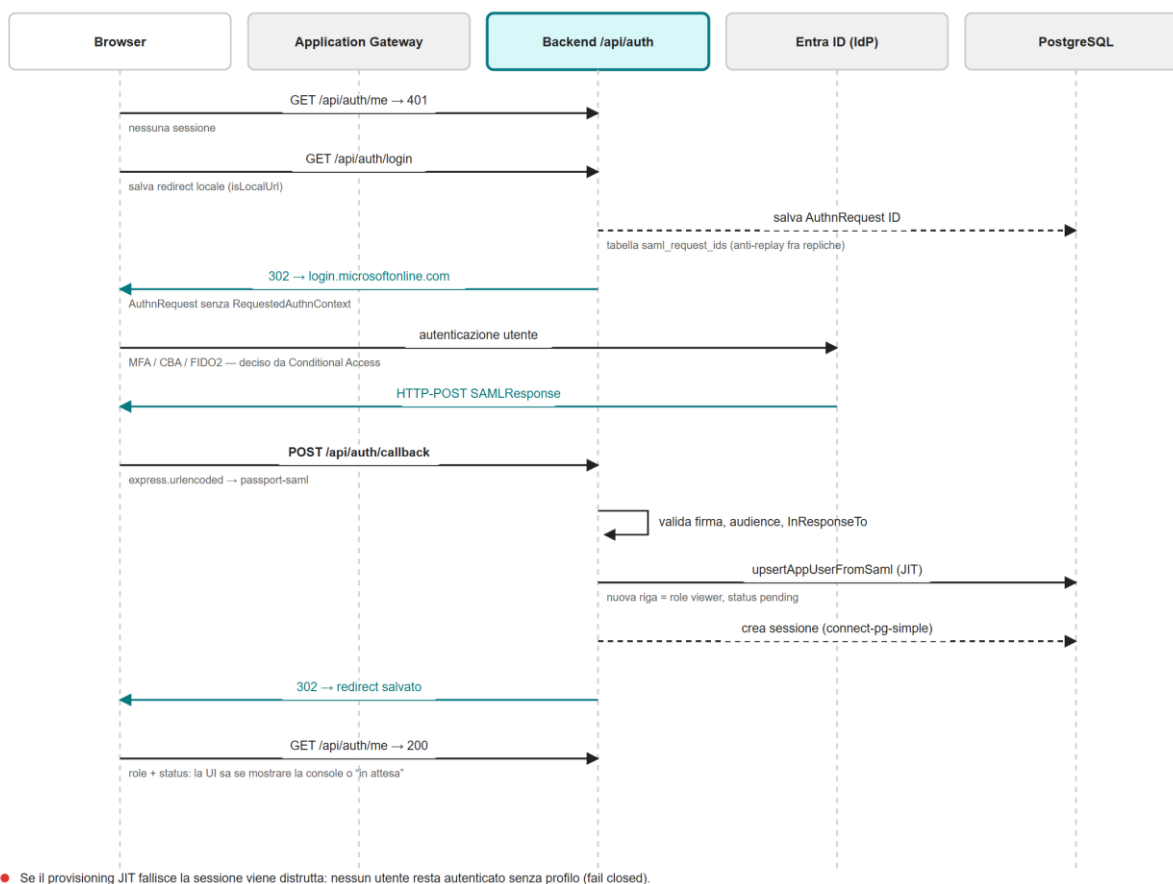
Superficie	Protezione
/api/healthz, /api/readyz, /api/health	Aperte per necessità della piattaforma. Non rivelano nulla oltre lo stato del processo e la raggiungibilità del database.
/api/auth/*	Aperte per costruzione (sono il percorso di accesso), ma protette da hardening SAML, limitazione dei tentativi e lista di indirizzi consentiti.
/api/*	Sessione + profilo attivo + ruolo + sede.
/api/admin/*	Le stesse, più <code>requireRole('admin')</code> all'ingresso del router. Comprende la lettura e la sostituzione delle password dei controller — deviazione D4, §10.4.
/api/directory/users	Sessione + ruolo <code>admin</code> o <code>operator</code> . Restituisce solo nomi visualizzati, di utenti abilitati su domini consentiti.
/api/ws	Sessione verificata e autorizzazione risolta sull'upgrade; l'ambito degli eventi è limitato alla sede.

Tabella 2 — Superficie esposta e relative protezioni.

3 Autenticazione

3.1 SSO SAML 2.0

- Accesso SSO SAML 2.0 e provisioning just-in-time



• Se il provisioning JIT fallisce la sessione viene distrutta: nessun utente resta autenticato senza profilo (fail closed).

Figura 1 — Sequenza dell'accesso SSO, con i punti in cui avviene la validazione.

Controllo	Stato	Nota
Libreria	@node-saml/passport-saml 5.x	Attivamente mantenuta; sostituisce la <code>passport-saml</code> non più aggiornata.
Firma dell'asserzione	Richiesta, incondizionata	Le dichiarazioni di identità devono essere firmate, sempre.
Firma della risposta	Richiesta, sovrascrivibile	Copre l'intero documento. Richiede su Entra la Signing Option «Sign SAML response and assertion».
Algoritmo	SHA-256	Nessun algoritmo deprecato.
Verifica del destinatario	<code>audience = SAML_ISSUER</code>	Impedisce il riuso di un'asserzione destinata a un'altra applicazione.
Anti-replay	<code>validateInResponseTo: ifPresent</code>	Con cache degli identificativi persistita su PostgreSQL (vedi §3.2).
Reindirizzamento aperto	Impedito	Il parametro <code>redirect</code> è accettato solo se punta alla stessa origine (<code>isLocalUrl</code>).

Controllo	Stato	Nota
Contesto di autenticazione	Non imposto	Vedi §3.3.
Single Logout	Supportato	Se l'IdP non risponde, l'uscita locale avviene comunque.
Certificato inutilizzabile	Degrado esplicito	Le rotte SSO rispondono 501 con la causa probabile; il processo non cade e l'accesso di emergenza resta disponibile.

Tabella 3 — Controlli sull'autenticazione SAML.

3.2 Cache anti-replay persistita

node-saml registra l'identificativo di ogni AuthnRequest e verifica il campo `InResponseTo` della risposta. Lo store predefinito è la memoria di processo, e la documentazione della libreria stessa dichiara che «non sarà sufficiente» quando richiesta e risposta possono essere gestite da processi diversi. Su Container Apps è il caso normale: basta un riavvio fra il reindirizzamento di accesso e la risposta dell'IdP, e con più repliche il problema è sistematico. Inoltre node-saml consuma l'identificativo anche sul percorso di errore, quindi ogni tentativo fallito ne brucia uno.

La cache è implementata su PostgreSQL (tabella `saml_request_ids`): la verifica sopravvive ai riavvii e funziona fra repliche, e la scadenza è applicata in SQL. **La protezione anti-replay non è indebolita: è soltanto affidabile.**

3.3 L'applicazione non impone il metodo di autenticazione

La libreria inserisce per impostazione predefinita un `RequestedAuthnContext` pari a `PasswordProtectedTransport` con confronto esatto. Entra ID onora il vincolo, quindi ogni utente che si autentica senza password — certificato, Windows Hello, FIDO2 — viene rifiutato:

```
AADSTS75011: Authentication method 'X509, MultiFactor, X509Device' by which the
user authenticated with the service doesn't match requested authentication
method 'Password, ProtectedTransport'.
```

Quali metodi siano accettabili è una decisione di **Conditional Access / Authentication Strength** del tenant, non del service provider: la strategia omette l'elemento del tutto. Non c'è nulla da cambiare sul lato Entra — un'applicazione SAML non ha un interruttore per ignorare un `RequestedAuthnContext` ricevuto. La correzione appartiene all'applicazione.

COME VERIFICARLO SU UN AMBIENTE ATTIVO

1. Aprire `/api/auth/login` e prendere il parametro `SAMLRequest` dal reindirizzamento verso `login.microsoftonline.com`.
2. Decodificare l'URL, decodificare base64, decomprimere.
3. L'XML risultante non deve contenere alcun elemento `RequestedAuthnContext`.

3.4 Sessione

Controllo	Valore
Cookie	<code>guestportal.sid</code> — <code>HttpOnly</code> , <code>SameSite=lax</code> , <code>Secure</code> in produzione
Firma	HMAC con <code>SESSION_SECRET</code> da Key Vault (≥ 64 caratteri casuali)
Persistenza	PostgreSQL con TLS e autenticazione a token Entra ID

Controllo	Valore
Durata	24 ore per una sessione SSO, 120 minuti per una di emergenza
Rigenerazione	Passport rigenera la sessione all'accesso (anti session-fixation)
Contenuto	Solo attributi di identità. Nessun ruolo, nessun permesso, nessun segreto.

Tabella 4 — Controlli sulla sessione.

Il ripiego di `SESSION_SECRET`

Esiste un valore di ripiego, esplicitamente marcato come insicuro nel codice, perché l'applicazione possa avviarsi in sviluppo locale senza che ogni sviluppatore debba generare un segreto. In produzione il valore **deve** arrivare da Key Vault: un difetto già corretto — la sintassi di riferimento sbagliata — aveva portato il segreto letterale del riferimento dentro la variabile, rendendo i cookie di sessione falsificabili a partire da informazioni pubbliche.

4 Autorizzazione

• Catena di autorizzazione di una richiesta

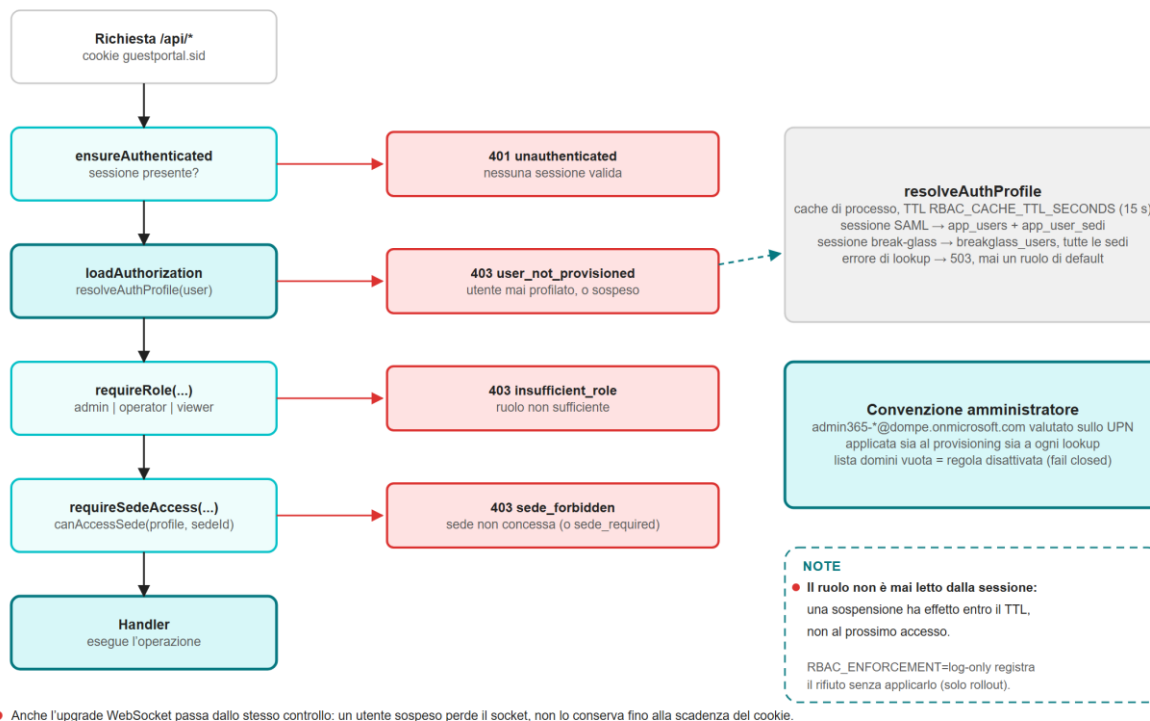


Figura 2 — Catena di autorizzazione: guardie, rifiuti e sorgenti del profilo.

4.1 Il principio

L'autorizzazione è risolta a ogni richiesta e non è mai serializzata in sessione. Un ruolo memorizzato in sessione sopravviverebbe fino alla scadenza del cookie: un utente sospeso continuerebbe a operare per 24 ore. Con la risoluzione per richiesta, una sospensione ha effetto entro il tempo di vita della cache — 15 secondi per impostazione predefinita, tenuto deliberatamente sotto l'intervallo di aggiornamento del cruscotto.

4.2 Ruoli e ambito

Ruolo	Operazioni	Ambito
viewer	Sola consultazione.	Sedi concesse.
operator	Consultazione, registrazione, revoca, reinvio credenziali.	Sedi concesse.
admin	Tutte, più il pannello di amministrazione.	Tutte le sedi.

Tabella 5 — Ruoli applicativi.

Ogni utente che completa l'accesso SSO ottiene una voce in directory al primo accesso, e quella voce nasce **bloccata**: può autenticarsi, non gli è concesso nulla. È un provisioning a negazione predefinita.

4.3 Fail closed

- Un errore nella risoluzione del profilo produce **503**, mai un profilo di ripiego. Un livello di autorizzazione che degrada ad «accetta» sotto carico non è un livello di autorizzazione.
- Una richiesta che richiede una sede e non la indica viene **rifiutata**, non servita con un valore predefinito: «nessuna sede» significava «usa la prima riga», ed è il ripiego che poteva far finire l'operazione di un operatore sul controller di un'altra sede.
- `null` (nessuna restrizione) e `[]` (nessuna concessione) non sono mai confusi: il primo è un amministratore, il secondo un utente che non deve vedere nulla.
- L'upgrade WebSocket attraversa lo stesso controllo: un utente sospeso perde il canale.

4.4 Amministratori per convenzione

Un UPN della forma `admin365-<qualcosa>@dompe.onmicrosoft.com` concede il ruolo di amministratore senza profilazione. Serve a raggiungere un ambiente appena installato senza esporre l'accesso di emergenza.

Il vincolo sul dominio sta facendo un lavoro reale

La regola lega privilegi pieni a una stringa contenuta in un indirizzo. Senza il vincolo di dominio, un account ospite (B2B) invitato nel tenant — il cui UPN appartiene al tenant di provenienza — potrebbe presentarsi come `admin365-x@attacker.com` e arrivare come amministratore di piattaforma. Per questa ragione, **una lista di domini vuota disattiva la regola invece di aprirla**: è l'unico punto in cui un valore vuoto non deve significare «nessuna restrizione».

La regola è valutata sullo **UPN** e non sull'indirizzo di posta: gli account amministrativi non hanno casella, e valutata sulla posta la regola mancava esattamente gli account per cui esiste. La chiave della directory resta comunque l'identificativo dell'oggetto in Entra: lo UPN è una colonna indicizzata ma non identificante, perché cambia a una rinomina.

4.5 Isolamento fra sedi

- La sede su cui si opera vive **in sessione**, non nei parametri della richiesta. Quando arrivava dalla query string, chiunque poteva leggere gli ospiti di un'altra sede modificando l'URL.
- Gli endpoint che agiscono su una sede verificano la concessione; quelli che scoprono la sede solo dopo una lettura la verificano subito dopo.
- Gli eventi in tempo reale sono filtrati per sede: i nomi degli ospiti sono dati personali.
- Per un utente non amministratore, indirizzo, porte e account del controller sono **rimossi** dalle risposte della API.

5 Gestione dei segreti

Segreto	Dove risiede	Come arriva all'applicazione
SESSION-SECRET	Key Vault	Variabile d'ambiente via riferimento a segreto della Container App
SAML-CERT	Key Vault	Idem
SAML-DECRYPTION-KEY	Key Vault (opzionale)	Idem
WLC-PASSWORD-<CODICE>	Key Vault, una per sede	Letta direttamente dal vault con l'identità gestita (<code>KEY_VAULT_URL</code>) all'avvio e alla ricarica; la variabile <code>WLC_PASSWORD_<CODICE></code> resta come ripiego. Leggibile e sostituibile da un amministratore — §10.4
MAIL-GRAPH-CLIENT-SECRET	Key Vault	Idem
Credenziale del database	Non esiste	Token Entra ID ottenuto dall'identità gestita a ogni nuova connessione
Password dell'ospite	Non esiste	Generata in memoria, consegnata, dimenticata. 12 caratteri interamente casuali (~69 bit)
Password di emergenza	Solo come hash scrypt in banca dati	Impostata da riga di comando
<code>sms_config.api_key</code>	Banca dati	Unico segreto residuo in banca dati ; campo vuoto, funzione dormiente

Tabella 6 — Inventario dei segreti.

- Nessun segreto è presente nel codice sorgente né nelle immagini.
- Nessun segreto transita dalla pipeline: la CI imposta i **riferimenti**, non i valori.
- L'autenticazione della pipeline verso Azure usa **identità federata OIDC**: non esiste un segreto di accesso al cloud da custodire.
- L'identità gestita del backend richiede **Key Vault Secrets User** per leggere e **Key Vault Secrets Officer** per sostituire una password di controller. Il secondo ruolo va assegnato con ambito ristretto ai soli segreti `WLC-PASSWORD-*`, non all'intero vault.
- Per la ricerca del referente la stessa identità richiede il permesso applicativo Microsoft Graph **User.Read.All** con consenso amministratore.
- Le risposte della API non restituiscono mai un segreto: la password del controller è omessa, la chiave SMS è omessa. Il pannello mostra solo **se** una password risulti configurata e **il nome** del segreto da richiedere.

Sintassi dei riferimenti a Key Vault

Container Apps **non** espande la sintassi `@Microsoft.KeyVault(SecretUri=...)` di App Service: al container arriverebbe il testo letterale. È un difetto già individuato, con conseguenze gravi — ogni accesso SSO falliva e `SESSION_SECRET` conteneva la stringa del riferimento. La procedura corretta usa i segreti della Container App (`keyvaultref:` / `secretref:`) ed è documentata nel runbook. **La conversione della pipeline è ancora aperta** (vedi §11).

6 Protezione dei dati

Misura	Attuazione
Minimizzazione	La password dell'ospite non è persistita. Quella del controller non è in banca dati. Il recapito telefonico è raccolto ma non utilizzato.
Robustezza delle credenziali ospite	Il prefisso fisso DOMPE- è stato rimosso: erano sei caratteri su quattordici che qualunque ospite poteva prevedere. Ora sono 12 caratteri casuali su un alfabeto di 55, con almeno una maiuscola, una minuscola e una cifra. Gli account già creati mantengono la password fino al reinvio.
Presenza dei dispositivi	Tenuta solo in memoria, per sede, con scadenza a 90 secondi. Mai persistita, mai esposta oltre il campo <code>connected</code> dell'elenco ospiti.
Oscuramento nei log	La password di destinazione è sostituita da *** prima della scrittura nello storico, e la trascrizione della sessione verso il controller passa da un mascheramento che sostituisce ogni password prima di essere registrata. La query string è esclusa dal log delle richieste (contiene <code>redirect</code> e <code>SAMLRequest</code>). Il token del database non è mai registrato: lo è solo la sua scadenza.
Cifratura in transito	HTTPS fino all'Application Gateway e da lì alle Container App; TLS verso PostgreSQL con verifica del certificato; TLS verso Key Vault, Graph ed Entra.
Cifratura a riposo	Cifratura gestita dalla piattaforma su PostgreSQL Flexible Server e Key Vault.
Isolamento	Un operatore vede solo gli ospiti della propria sede, in console, nella API e nel canale in tempo reale.
Ricerca nella directory	Dal backend escono solo i nomi visualizzati, di utenti abilitati su domini consentiti. Nulla è memorizzato, né sul server né nel browser. Il testo cercato non viene registrato: è il nome di una persona.
Cancellazione	L'eliminazione di un ospite rimuove la riga e revoca l'account sul controller. L'eliminazione di un utente rimuove anche le concessioni.

Tabella 7 — Misure di protezione dei dati.

Ritenzione dello storico

La tabella `sync_logs` non ha una politica di ritenzione automatica e cresce di circa 14.400 righe al giorno per effetto della sola sincronizzazione. Conserva nomi utente e, sulle voci di invio, gli indirizzi dei destinatari. Definire una ritenzione è una raccomandazione aperta.

7 Sicurezza verso i controller

Il percorso verso i controller è l'unico che lascia il perimetro Azure e porta con sé le credenziali più sensibili del sistema. Merita una lettura unitaria, perché le due deviazioni **D2** e **D3** insistono sullo stesso canale e il rischio è quindi cumulativo, non distribuito.

Controllo	Stato
Iniezione di comandi IOS-XE	Chiusa. Ogni valore che finisce in un comando passa da validazione: nessun capoverso, nessun byte nullo, alfabeto ristretto per username e password, durata come intero entro limiti.
Autenticazione del server SSH	Disattivata — deviazione D2.
Autenticazione del server TLS	Disattivata in produzione — deviazione D3.
Cifratura del canale	Attiva su entrambi: SSH e TLS cifrano, pur senza autenticare il server.
Egress	Ristretto alla rete di gestione: il percorso non attraversa reti non gestite.
Ambito della credenziale	Una password per sede: la compromissione di una non compromette le altre.
Persistenza della credenziale	Nessuna: la password del controller non è in banca dati, quindi un'intercettazione non dà accesso persistente alla configurazione dell'applicazione.

Tabella 8 — Controlli sul percorso verso i controller.

8 Supply chain e immagini

- Due immagini distinte, **multi-stage**: nell'immagine finale finiscono solo gli artefatti compilati e le dipendenze di produzione.
- Entrambe girano con **utente non privilegiato** (`app` sul backend, UID 101 sul frontend).
- `apk upgrade` nelle fasi di runtime per allineare i pacchetti di sistema.
- **Trivy** in tre punti: filesystem, immagine backend, immagine frontend. Il cancello blocca sulle vulnerabilità **CRITICAL** ed è coerente fra i tre scanner. I risultati sono caricati in GitHub Security.
- `docker-security.yml` è un workflow autonomo che gira su ogni push e pull request.
- Il lockfile del frontend è obbligatorio: la sua assenza fa fallire la build invece di produrre un albero di dipendenze non riproducibile.
- Tag immagine **immutabile** pari allo SHA del commit, più un alias mutabile per ambiente: ogni revisione è riconducibile a un commit preciso.
- Dependabot è attivo sul repository.

9 Registrazione e audit

Evento	Livello	Campi
Richiesta HTTP	info	correlationId, metodo, percorso, stato, durata, user-agent, IP
Rifiuto di autorizzazione	warn	event: authz-denied, motivo, soggetto, percorso, metodo, correlationId
Provisioning JIT	info	event: sso-jit-provisioning, soggetto, creato, ruolo, stato, amministratore per convenzione
Tentativo di accesso di emergenza	warn	event: breakglass-login-denied, motivo, IP, user-agent, correlationId
Accesso di emergenza riuscito	warn	event: breakglass-login-success, nome utente, durata della sessione, IP
Blocco di un account di emergenza	warn	event: breakglass-account-locked, nome utente, fine del blocco
Modifica di un profilo utente	warn	event: admin-user-updated, attore, destinatario, stato prima e dopo
Eliminazione di un utente	warn	event: admin-user-deleted, attore, destinatario e ciò che la riga concedeva (indirizzo, ruolo, stato, sedi): dopo l'eliminazione il log è l'unica traccia rimasta
Lettura degli account di emergenza	warn	event: admin-breakglass-list, attore
Modifiche alle sedi	warn	event: admin-sede-*, attore, codice sede
Password di un controller	warn	event: admin-wlc-password-viewed · -changed, attore, sede, correlationId. Una lettura è tracciata come una scrittura.
Ricarica delle password	warn	event: admin-wlc-reload, attore, elenchi delle sedi caricate, mancanti e fallite
Errore Key Vault	error	event: admin-wlc-keyvault-error, operazione, sede, messaggio sintetico dell'SDK
Operazioni sui controller e invii	Tabella sync_logs	Azione, metodo, destinazione, codice di stato

Tabella 9 — Eventi registrati e relativi campi.

Perché anche la sola lettura degli account di emergenza è registrata

Sapere quali account di emergenza esistono, quali sono abilitati e quali bloccati è di per sé un'informazione utile a un attaccante. La lettura è quindi tracciata come le modifiche.

ALERT OBBLIGATORIO

Un alert su Log Analytics per gli accessi di emergenza riusciti è un requisito, non una raccomandazione: la query è riportata nel runbook operativo. Un accesso di emergenza riuscito è un evento su cui qualcuno deve guardare, ogni volta.

10 Deviazioni consapevoli

Quattro deviazioni sono state assunte esplicitamente, con il rischio rappresentato al richiedente e accettato. Sono documentate qui perché una deviazione registrata e sorvegliata è gestibile, una dimenticata no.

10.1 D1 — Accesso di emergenza senza secondo fattore

Campo	Contenuto
Che cosa	Accesso locale con nome utente e password (<code>POST /api/auth/breakglass/login</code>) che consente di usare la console quando Entra ID o il collegamento SAML non funzionano.
Perché	Continuità operativa: senza di esso un'indisponibilità dell'IdP rende la console inutilizzabile e gli ospiti non registrabili.
Deviazione	Aggira Conditional Access e MFA di Entra. Non ha un secondo fattore : è una scelta esplicita del richiedente, presa dopo che il rischio è stato rappresentato. L'alternativa proposta era password + TOTP sulle sole librerie standard, senza dipendenze aggiuntive.
Rischio residuo	Una password compromessa è sufficiente per accedere alla console con pieni privilegi. Il rischio non è eliminato , solo ridotto.

Tabella 10 — Deviazione D1.

CONTROLLI COMPENSATIVI — TUTTI NEL CODICE, NON SOLO PROCEDURALI

- Interruttore generale `BREAKGLASS_ENABLED`, spento per default: finché non viene acceso deliberatamente l'endpoint risponde 404.
- Lista CIDR valutata prima di ogni altra cosa, **fail-closed** se tutte le voci sono malformate; chi è fuori riceve 404 e non vede nemmeno il collegamento nell'interfaccia.
- Hash script (RFC 7914) con salt per record e confronto a tempo costante; nessuna dipendenza nativa aggiuntiva.
- Blocco dell'account persistito in banca dati, quindi **globale** su tutte le repliche; solo la password errata lo incrementa.
- Limitazione per indirizzo di origine a finestra scorrevole, in memoria e quindi per replica: è un controllo aggiuntivo, non quello principale.
- Verifica a **costo costante** (hash fittizio per un account inesistente) e **un solo messaggio d'errore** per ogni causa: nessuna enumerazione né per tempi né per testo.
- Rigenerazione della sessione all'accesso e durata del cookie ridotta (120 minuti contro 24 ore).
- Scadenza per account, per limitare nel tempo la validità della credenziale.
- Audit a livello `warn` di **ogni** tentativo, riuscito o meno, con motivo, IP, user-agent e identificativo di correlazione.
- **Creazione e rotazione della password solo da riga di comando**. Gli endpoint esposti possono abilitare, disabilitare e sbloccare, non creare: una sessione amministrativa compromessa non può coniarci un aggiramento permanente dell'SSO.
- Guardia `last_breakglass`: il pannello rifiuta di disabilitare l'ultimo account utilizzabile.
- Account di bootstrap creato dalla migrazione **solo** se la password di seed è presente e lunga almeno 16 caratteri, e **solo se assente**: non ruota una password già cambiata né riabilita un account disabilitato di proposito.

- Banner permanente e badge in console: una sessione di emergenza non può passare per una sessione normale.
- L'uscita da una sessione di emergenza **non** tenta il Single Logout SAML: il soggetto è locale e Entra non lo conosce.

LIMITI NOTI, A VERBALE

1. Nessun secondo fattore — vedi rischio residuo.
2. Dipende da PostgreSQL: copre un'indisponibilità di **Entra**, non del **database**.
3. La limitazione per indirizzo è per replica; il blocco per account è globale.
4. Una lista di indirizzi vuota espone l'endpoint: in assenza di secondo fattore è il controllo compensativo più efficace e va popolata con gli intervalli di uscita aziendali e VPN. Il backend registra un avviso esplicito all'avvio se la funzione è attiva senza lista.
5. Un amministratore compromesso può **disabilitare** (non creare) un account di emergenza: la guardia impedisce di azzerarli tutti e ogni azione è tracciata, ma resta un modo per degradare la disponibilità del percorso.
6. La password di seed è un segreto e va legata **solo** al job di migrazione, non al container backend. Dopo il bootstrap va ruotata da riga di comando e archiviata nel gestore di password: il valore in Key Vault a quel punto non è più quello attivo.
7. L'account di emergenza è anche il bootstrap della profilazione: finché non esiste un amministratore profilato è l'unico che può crearne uno. L'alternativa, senza esporre nulla in rete, è `make appusers` eseguito nel container.

10.2 D2 — Verifica della chiave host SSH disattivata

Campo	Contenuto
Che cosa	<code>WLC_SSH_VERIFY_HOST_KEY</code> a <code>false</code> : il client SSH non verifica la chiave host dei controller.
Perché	I cinque controller hanno cinque chiavi diverse, mentre la variabile che contiene il valore atteso è singola e confrontata con tutti. Con la verifica attiva funzionerebbe una sola sede e le altre quattro fallirebbero closed: la funzionalità sarebbe inutilizzabile su quattro sedi su cinque.
Deviazione	La sessione SSH non è autenticata, quindi esposta a interposizione sul percorso verso il controller. Su quella sessione passano la password amministrativa del controller e le credenziali degli ospiti.
Rischio residuo	Chi si interpone fra backend e controller può intercettare quelle credenziali. Ridotto dal percorso su rete interna gestita con egress ristretto, non eliminato .

Tabella 11 — Deviazione D2.

CONTROLLI E MITIGAZIONI

- Egress del backend limitato alla rete di gestione: il percorso non attraversa reti non gestite.
- Lo stato è **visibile**: il backend registra un avviso la prima volta che apre una connessione non verificata, una sola volta per processo.
- Quando la verifica viene attivata è **fail-closed**: senza il valore atteso rifiuta di connettersi anziché procedere.
- Il flag è per ambiente: si può attivare su un ambiente di prova senza toccare il codice.

Prerequisito per chiudere la deviazione: chiave host **per sede** (`WLC_SSH_HOST_KEY_<CODICE>`), con lo stesso schema già usato per le password), più la raccolta delle cinque impronte dai controller.

10.3 D3 — Verifica del certificato TLS dei controller disattivata

Campo	Contenuto
Che cosa	<code>WLC_TLS_REJECT_UNAUTHORIZED=false</code> in produzione: il client HTTPS verso i controller non verifica il certificato del server.
Perché	Il Catalyst 9800 presenta un certificato autofirmato , che con la verifica attiva viene sempre rifiutato rendendo impossibile la verifica delle credenziali. Le alternative — certificati attendibili sui cinque controller, oppure pinning per sede — sono state valutate e rinviate su decisione del richiedente.
Deviazione	Il canale HTTPS verso il controller non è autenticato. Su quel canale viaggia l'intestazione di autenticazione Basic, cioè la password amministrativa del controller in base64, non cifrata.
Rischio residuo	Chi si interpone può leggere quella password e impersonare il controller. Ridotto dal percorso su rete interna gestita, non eliminato .

Tabella 12 — Deviazione D3.

D2 e D3 vanno lette insieme

Entrambe rimuovono l'autenticazione del **server** sullo stesso percorso di rete. Il rischio è cumulativo su un unico canale, non distribuito su due canali distinti.

CONTROLLI E MITIGAZIONI

- Egress limitato alla rete di gestione.
- La password amministrativa del controller non è in banca dati: un'intercettazione non dà accesso persistente alla configurazione dell'applicazione.
- Gli errori TLS sono classificati e non più confusi con problemi di rete: un cambio di stato del certificato è diagnosticabile.
- Il flag è per ambiente.

Prerequisito per chiudere la deviazione: pinning per sede (`WLC_TLS_CA_<CODICE>` con il certificato di ciascun controller) oppure certificati emessi da una CA aziendale installati sui cinque controller. Il pinning mantiene la verifica attiva e rileva l'interposizione **senza** toccare i controller, ed è la via meno costosa.

10.4 D4 — Password dei controller leggibile e modificabile via HTTP

Campo	Contenuto
Che cosa	Dal pannello un amministratore può vedere la password del controller di una sede (letta live da Key Vault), sostituirla creando una nuova versione del segreto, e ricaricare in memoria tutte le password senza riavviare.
Perché	Richiesta operativa: la rotazione della password di un controller non deve dipendere da un ticket al team di piattaforma e da una nuova revisione dell'applicazione, e una sede nuova deve poter essere messa in servizio dal solo pannello.
Deviazione	Ribalta, per questo unico valore, la regola «nessun segreto attraversa la API». Una sessione amministrativa compromessa può leggere la password amministrativa di ogni controller e sostituirla nel vault, negando il servizio sulla sede finché non viene ripristinata. Il backend passa da Secrets User a Secrets Officer .
Rischio residuo	La password del controller diventa raggiungibile da chi controlla una sessione amministrativa, non più soltanto da chi ha accesso a Key Vault.

Tabella 13 — Deviazione D4.

CONTROLLI E MITIGAZIONI — NEL CODICE

- Solo ruolo **admin**: l'intero router amministrativo è dietro la guardia, e l'autorizzazione è risolta a ogni richiesta.
- **Ogni** lettura e **ogni** scrittura sono tracciate a livello **warn** con attore, sede e identificativo di correlazione, più una riga nello storico visibile in console. Una lettura è sensibile quanto una scrittura, e viene trattata così.
- Lettura **su richiesta**, una sede alla volta: la password non fa parte del record di sede né di alcun elenco. Risposta con **Cache-Control: no-store**; nel pannello il valore viene tolto dallo stato quando si nasconde e comunque dopo **30 secondi**.
- Una scrittura **non restituisce mai** il valore, e il valore non compare in alcun log.
- La password è validata come ogni credenziale destinata a IOS-XE: ASCII stampabile, nessun a capo. Sono rifiutati gli spazi iniziali e finali, che il validatore rimuoverebbe in silenzio salvando un valore diverso da quello impostato sul controller — un disallineamento che emergerebbe solo più tardi, come collegamento fallito.
- **Key Vault resta l'unico archivio**: nulla va in banca dati. La copia in memoria è per processo e si ricostruisce all'avvio.
- Un errore di Key Vault non spegne una sede funzionante: la ricarica conserva il valore precedente per le sedi non leggibili, e l'avvio non fallisce.

LIMITI NOTI, A VERBALE

1. Il ruolo **Key Vault Secrets Officer** va concesso al backend. Per contenere l'impatto va assegnato con ambito sui singoli segreti **WLC-PASSWORD-***, non sull'intero vault.
2. La copia in memoria è per replica: con più repliche una modifica fatta dal pannello raggiunge le altre al riavvio o alla ricarica successiva. Oggi il backend gira con una sola replica.
3. Resta invariata l'esposizione del canale verso il controller descritta in **D2** e **D3**.

L'applicazione non tocca il controller

Salvare una password qui **non la cambia sull'apparato**. La sequenza corretta è: cambiarla prima sul controller, poi registrarla nel pannello. Invertire l'ordine mette fuori servizio la sede fino alla correzione.

11 Stato di conformità

Valutazione sulla checklist §13 della baseline di piattaforma.

#	Requisito	Stato	Nota
1	Due immagini / Dockerfile indipendenti	Conforme	Stateless, non-root, multi-stage.
2	README e <code>.gitignore</code> ; nessun segreto nel repository	Conforme	Documentazione a più livelli; segreti rimossi.
3	Configurazione da ambiente; segreti solo da Key Vault	Conforme	Password del controller per sede, lette dal vault via SDK con ripiego sull'ambiente, mai in banca dati; visibili e modificabili solo da un amministratore, con audit (D4). Resta <code>sms_config.api_key</code> , campo vuoto e funzione nascosta.
4	API sotto <code>/api</code> , stessa origine, nessun CORS	Conforme	CORS rimosso.
5	Chiamate frontend→backend lato server	Non applicabile	Nessun rendering lato server.
6	Dietro Application Gateway (URL relativi, intestazioni inoltrate)	Conforme	<code>trust proxy</code> ; WebSocket sotto <code>/api/ws</code> .
7	Accesso ad Azure con credenziale gestita e scope esplicito	Conforme	Database, Key Vault e Microsoft Graph (ricerca referente) con l'identità gestita del backend; posta con client credentials.
8	SSO Entra SAML 2.0	Conforme	Hardening completo applicato.
9	Migrazioni idempotenti, nessun superuser	Conforme	Punto d'ingresso da riga di comando funzionante.
10	Pipeline a stadi, mappatura dei rami, Trivy	Conforme	Cancello Trivy coerente sulle CRITICAL.
11	Log strutturati, sonde a specifica, arresto controllato	Conforme	Correlazione, <code>/healthz</code> e <code>/readyz</code> , SIGTERM.
12	Token Entra per PostgreSQL con rinnovo	Conforme	Scope corretto; token per connessione.
13	Risorse ai valori predefiniti	Conforme	Allineate.
14	Nessun autoscaling, multi-revisione o ingress pubblico	Parziale	Da completare l'allineamento del provisioning al modello consume-only.
15	Nessun artefatto locale a runtime; test senza infrastruttura	Conforme	765 test unitari, 31 casi end-to-end (conteggio statico).
16	Verifica post-deploy identica sui tre rami	Non applicabile	Verifiche eseguite manualmente in questa fase.
17	Dati di riferimento idempotenti, solo in sviluppo	Conforme	<code>SEED_ENABLED</code> a <code>false</code> in produzione.
18	Punti aperti elencati	Parziale	La pipeline non modifica più l'Application Gateway.

Tabella 14 — Stato di conformità sulla checklist §13.

Sintesi: 13 conformi, 2 parziali, 1 parziale sui default TLS (deviazioni D2 e D3), 2 non applicabili. La deviazione D4 non altera lo stato della checklist: il requisito 3 chiede che i segreti stiano in Key Vault, e continuano a starci.

12 Backlog di remediation

Priorità	Azione	Rif.	Tipo
P0	Convertire la pipeline e lo script di preflight alla sintassi dei segreti di Container Apps (<code>keyvaultref:</code> / <code>secretref:</code>). Finché non è fatto, un deploy dalla pipeline rompe di nuovo l'SSO e riporta <code>SESSION_SECRET</code> a un valore pubblico.	7.1	Codice (pipeline)
P0	Creare il principal Entra su PostgreSQL mappato all'identità gestita del backend.	3.3	Infrastruttura, una tantum
P1	Chiave host SSH per sede più raccolta delle cinque impronte — prerequisite per chiudere D2.	D2	Codice + infrastruttura
P1	Pinning TLS per sede — mantiene la verifica attiva e rileva l'interposizione senza toccare i controller; prerequisite per chiudere D3.	D3	Codice + infrastruttura
P1	Completare l'adozione delle risorse di piattaforma e l'allineamento di nomi e hostname.	4	Architetturale
P1	Assegnare all'identità del backend il ruolo Key Vault Secrets Officer con ambito sui soli segreti <code>WLC-PASSWORD-*</code> , e il permesso Graph <code>User.Read.All</code> con consenso amministratore.	D4	Infrastruttura
P2	Rivedere la copia in memoria delle password prima di passare a più di una replica.	D4	Codice
P2	Definire una ritenzione per <code>sync_logs</code> .	—	Operativo
P2	Attivare o rimuovere il canale SMS: allo stato attuale è superficie inutilizzata con un segreto in banca dati.	—	Codice

Tabella 15 — Backlog di remediation aperto.

L'elemento più urgente

La conversione della sintassi dei riferimenti a Key Vault nella pipeline è l'unico punto in cui un'azione di routine — un deploy — può **reintrodurre** un difetto già corretto a mano. Va affrontato con attenzione: referenziare un segreto inesistente fa fallire la revisione, quindi le variabili opzionali vanno gestite in modo condizionale.